* Introduction to Cyber Security *

Module 1: Introduction to Cyber Security

Organizational Data

Traditional Data

Typically generated and maintained by all organizations:

- **Transactional data** such as details relating to buying and selling, production activities and basic organizational operations such as any information used to make employment decisions.
- **Intellectual property** such as patents, trademarks and new product plans, which allows an organization to gain economic advantage over its competitors. This information is often considered a trade secret and losing it could prove disastrous for the future of a company.
- **Financial data** such as income statements, balance sheets and cash flow statements, which provide insight into the health of a company.

IoT and Big Data

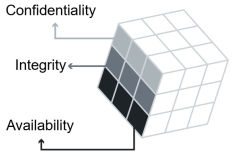
The emergence of IoT has brought exponential growth in data, and created an area of interests in technology and business called "**Big Data**".

The Cube

The McCumber Cube is a model framework created by John McCumber in 1991 to help organizations establish and evaluate information security initiatives by considering all of the related factors that impact them. This security model has three dimensions:

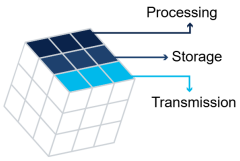
1. The foundational principles for protecting information systems.
2. The protection of information in each of its possible states.
3. The security measures used to protect data.

The foundational principles for protecting information



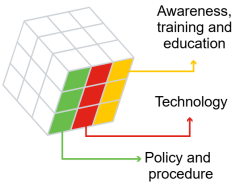
- **Confidentiality** is a set of rules that prevents sensitive information from being disclosed to unauthorized people, resources and processes. **Methods to ensure confidentiality include data encryption, identity proofing and two factor authentication**.
- **Integrity** ensures that system information or processes are protected from intentional or accidental modification. One way **to ensure integrity is to use a hash function or checksum**.
- **Availability** means that authorized users are able to access systems and data when and where needed and those that do not meet established conditions, are not. This can be achieved by **maintaining equipment, performing hardware repairs, keeping operating systems and software up to date, and creating backups**.

The protection of information in each state



- **Processing** refers to data that is being used to perform an operation such as updating a database record (data in process).
- **Storage** refers to data stored in memory or on a permanent storage device such as a hard drive, solid-state drive or USB drive (data at rest).
- **Transmission** refers to data traveling between information systems (data in transit).

The security measures used to protect data



- **Awareness, training and education** are the measures put in place by an organization to ensure that users are knowledgeable about potential security threats and the actions they can take to protect information systems.
- **Technology** refers to the software- and hardware-based solutions designed to protect information systems such as firewalls, which continuously monitor your network in search of possible malicious incidents.
- **Policy and procedure** refers to the administrative controls that provide a foundation for how an organization implements information assurance, such as incident response plans and best practice guidelines.

The Very Basic Security Measures

- investing in cybersecurity training for all staff so that they are aware of and able to spot a cyber attack
- enforcing two factor authentication for employees accessing files and applications that contain sensitive data
- maintaining log files and ongoing monitoring to identify anomalous behavior that might indicate a data breach
- storing the passwords of customers using a combination of salting and robust hashing algorithms
- separating cloud-based resources from the public Internet into an isolated private network segment
- granting employee access to personal data and internal systems only via a secure VPN connection.

Cyber Attackers

The 3 basic groups:

Amateurs: Known as “script kiddies”, coined in the 90s.
- They generally use existing tools or instructions on the internet to launch attacks.

Hackers: Generally fall into 3 sub-categories
1. White Hat attackers: break into networks or computer systems to identify any weaknesses so that the security of a system or network can be improved. These break-ins are done with prior permission and any results are reported back to the owner.
2. Gray Hat attackers: may set out to find vulnerabilities in a system but they will only report their findings to the owners of a system if doing so coincides with their agenda. Or they might even publish details about the vulnerability on the internet so that other attackers can exploit it.
3. Black Hat attackers: take advantage of any vulnerability for illegal personal, financial or political gain.

Organized Hackers: These attackers include organizations of cyber criminals, hacktivists, terrorists and state-sponsored hackers. They are usually highly sophisticated and organized, and may even provide cybercrime as a service to other criminals.
- Hacktivists make political statements to create awareness about issues that are important to them.
- State-sponsored attackers gather intelligence or commit sabotage on behalf of their government. They are usually highly trained and well-funded and their attacks are focused on specific goals that are beneficial to their government.

Internal and External Threats

Internal
Employees, contract staff or trusted partners can accidentally or intentionally:
- Mishandle confidential data
- Facilitate outside attacks by connecting infected USB media into the organization’s computer system.
- Invite malware onto the org’s network by clicking on malicious emails or websites.
- Threaten the operations of internal servers or network infrastructure devices.

External
Amateurs or skilled attackers outside of the organization can:
- Exploit vulnerabilities in the network.
- Gain unauthorized access to computing devices.
- Use social engineering to gain unauthorized access to organizational data.

– – Continued – –

Cyberwarefare

Cyberwarfare, as its name suggests, is the use of technology to penetrate and attack another nation's computer systems and networks in an effort to cause damage or disrupt services, such as shutting down a power grid.

One example of a state-sponsored attack involved the Stuxnet malware that was designed not just to hijack targeted computers but to actually cause physical damage to equipment controlled by computers!

The main reason for resorting to cyberwarfare is to gain advantage over adversaries, whether they are nations or competitors. Additional reason:

- To gather compromised information and/or defense secrets
- To impact another nation's infrastructure

Module 2: Attacks, Concepts and Techniques.

Analyzing a Cyber Attack

Types of Malware

- **Spyware**: Designed to track and spy on you, spyware monitors your online activity and can log every key you press on your keyboard, as well as capture almost any of your data, including sensitive personal information such as your online banking details.
    - Spyware does this by modifying the security settings on your devices.
    - It often bundles itself with legitimate software or Trojan horses.
- **Adware**: Adware is often installed with some versions of software and is designed to automatically deliver advertisements to a user, most often on a web browser.
    - It is common for adware to come with spyware.
- **Backdoor**: used to gain unauthorized access by bypassing the normal authentication procedures to access a system.
- **Ransomware**: designed to hold a computer system or the data it contains captive until a payment is made.
    - Ransomware usually works by encrypting your data so that you can't access it.
    - Ransomware is often spread through phishing emails that encourage you to download a malicious attachment or through a software vulnerability.
- **Scareware**: A type of malware that uses 'scare' tactics to trick you into taking a specific action.
    - Scareware mainly consists of operating system style windows that pop up to warn you that your system is at risk and needs to run a specific program for it to return to normal operation.
- **Rootkit**: This malware is designed to modify the operating system to create a backdoor, which attackers can then use to access your computer remotely.
    - Rootkits can also modify system forensics and monitoring tools, making them very hard to detect.
    - In most cases, a computer infected by a rootkit has to be wiped and any required software reinstalled.
- **Virus**: A virus is a type of computer program that, when executed, replicates and attaches itself to other executable files, such as a document, by inserting its own code.
    - Viruses can be relatively harmless, such as those that display a funny image, or they can be destructive.
    - Viruses can also be programmed to mutate in order to avoid detection.
    - Most viruses are spread by USB drives, optical disks, network shares or email.
- **Trojan Horse**: This malware carries out malicious operations by masking its true intent.
- **Worms**: This is a type of malware that replicates itself in order to spread from one computer to another.
    - Unlike a virus, which requires a host program to run, worms can run by themselves.
    - They exploit system vulnerabilities, they have a way to propagate themselves, and they all contain malicious code (payload) to cause damage to computer systems or networks.
    - Worms are responsible for some of the most devastating attacks on the Internet.
        - In 2001, the Code Red worm had infected over 300,000 servers in just 19 hours.

Regardless of the type of malware a system has been infected with, there are some common symptoms to look out for. These include:

- an increase in central processing unit (CPU) usage, which slows down your device
- your computer freezing or crashing often
- a decrease in your web browsing speed
- unexplainable problems with your network connections
- modified or deleted files
- the presence of unknown files, programs or desktop icons
- unknown processes running
- programs turning off or reconfiguring themselves
- emails being sent without your knowledge or consent.

Methods of Infiltration

Social Engineering

Social engineering is the manipulation of people into performing actions or divulging confidential information. Social engineers often rely on people's willingness to be helpful, but they also prey on their weaknesses.

- **Pretexting**: This is when an attacker calls an individual and lies to them in an attempt to gain access to privileged data.
- **Tailgating**: This is when an attacker quickly follows an authorized person into a secure, physical location
- **Quid pro quo**: This is when an attacker requests personal information from a person in exchange for something, like a free gift.

Denial of Service (DoS)

A type of network attack that is relatively simple to carry out, even by an unskilled attacker. A DoS attack results in some sort of interruption of network service to users, devices or applications.

1. Overwhelming quantity of traffic: When a network, host or application is sent an enormous amount of data at a rate which it cannot handle.
2. Maliciously formatted packets: When a maliciously formatted packet is sent, the receiver won't be able to handle it.
    a. Example: An attacker forwards packets containing errors or improperly formatted packets that cannot be identified by an application, causing the receiving device to run slowly and/or crash.

Distributed DoS

A Distributed DoS (DDoS) attack is similar to a DoS attack but originates from multiple, coordinated sources. For example:

- An attacker builds a network (botnet) of infected hosts called zombies, which are controlled by handler systems.
- The zombie computers will constantly scan and infect more hosts, creating more and more zombies.
- When ready, the hacker will instruct the handler systems to make the botnet of zombies carry out a DDoS attack.

Botnet

A bot computer is typically infected by visiting an unsafe website or opening an infected email attachment or infected media file.

A botnet is a group of bots, connected through the Internet, that can be controlled by a malicious individual or group.

- It can have tens of thousands, or even hundreds of thousands, of bots that are typically controlled through a command and control server.
- These bots can be activated to distribute malware, launch DDoS attacks, distribute spam email, or execute brute-force password attacks.
- Cybercriminals will often rent out botnets to third parties for nefarious purposes.

Many organizations, like Cisco, force network activities through botnet traffic filters to identify any botnet locations.

1. Infected bots try to communicate with a command and control host on the Internet.
2. The Cisco Firewall botnet filter is a feature that detects traffic coming from devices infected with the malicious botnet code.
3. The cloud-based Cisco Security Intelligence Operations (SIO) service pushes down updated filters to the firewall that match traffic from new known botnets.
4. Alerts go out to Cisco's internal security team to notify them about the infected devices that are generating malicious traffic so that they can prevent, mitigate and remedy these.

UPDATE via ChatGPT 5.2:
Live verification performed (web): yes — checked current Cisco docs/pages about Botnet Traffic Filter + its update mechanism, plus Cisco's current threat-intel org (Talos). Main gap: **"SIO" is an older brand name** you'll still see in training material; Cisco largely positions this capability today under **Talos + Security Intelligence feeds**. Cisco+2Talos Intelligence+2

Cisco Security Intelligence Operations (SIO) is Cisco's cloud-backed threat-intelligence function that collects global threat data and **pushes reputation/IOC updates** to Cisco security products so they can **detect/block "known bad" traffic** faster. Cisco+2Cisco+2

- **What it delivers:** continuously updated "known bad" indicators (IPs/domains/URLs, etc.) that devices can use for reputation checks and blocking/logging. Cisco+1
- **Where you see it:** features like **ASA Botnet Traffic Filter** rely on a **dynamic database** that gets periodic updates from Cisco update servers (that's the "SIO pushes filters" idea). Cisco+1

On-Path attacks

On-path attackers intercept or modify communications between two devices, such as a web browser and a web server, either to collect information from or to impersonate one of the devices.

This type of attack is also referred to as a man-in-the-middle or man-in-the-mobile attack.

SEO Poisoning

SEO poisoning is a technique where attackers **manipulate search engine rankings** so malicious websites appear **high in legitimate search results**, increasing the chance users will click them.

Key points:

- Attackers abuse **popular or trending search terms** to rank malicious pages highly.
- Victims are redirected to sites that deliver **malware, phishing, or social engineering**.
- It **exploits trust in search engines**, not a technical vulnerability in the browser itself.

Wi-Fi Password Cracking

Never share private or internal Wi-Fi credentials with others.

Access to secured networks must follow policy and authorization, not convenience or trust.

Password Attacks

1. **Password Spraying**: This technique attempts to gain access to a system by 'spraying' a few commonly used passwords across a large number of accounts.
    a. This technique allows the perpetrator to remain undetected as they avoid frequent account lockouts.
2. **Dictionary Attacks**: A hacker systematically tries every word in a dictionary or a list of commonly used words as a password in an attempt to break into a password-protected account.
3. **Brute-Force Attacks**: The simplest and most commonly used way of gaining access to a password-protected site, brute-force attacks see an attacker using all possible combinations of letters, numbers and symbols in the password space until they get it right.
4. **Rainbow Attacks**: A rainbow table is a large dictionary of precomputed hashes and the passwords from which they were calculated.
    a. A rainbow attack compares the hash of a password with those stored in the rainbow table. When an attacker finds a match, they identify the password used to create the hash.
5. **Traffic Interception**: Plain text or unencrypted passwords can be easily read by other humans and machines by intercepting communications.
    a. If you store a password in clear, readable text, anyone who has access to your account or device, whether authorized or unauthorized, can read it.

10 Advanced Persistent Threats

Attackers also achieve infiltration through **advanced persistent threats** (**APTs**) — a multi-phase, long term, stealthy and advanced operation against a specific target. For these reasons, an individual attacker often lacks the skill set, resources or persistence to perform APTs.

Due to the complexity and the skill level required to carry out such an attack, an APT is usually well-funded and typically targets organizations or nations for business or political reasons.

Its main purpose is to deploy customized malware on one or more of the target's systems and remain there undetected.

Security Vulnerability and Exploits

- **Security vulnerabilities** are any kind of software or hardware defect.
- A program written to take advantage of a known vulnerability is referred to as an **exploit**.

A cybercriminal can use an exploit against a vulnerability to carry out an attack, the goal of which is to gain access to a system, the data it hosts or a specific resource.

– – Continued – –

Hardware Vulnerabilities

Hardware vulnerabilities are most often the result of hardware design flaws. Hardware vulnerabilities are specific to device models and are not generally exploited through random compromising attempts.

- While hardware exploits are more common in highly targeted attacks, traditional malware protection and good physical security are sufficient protection for the everyday user.

Rowhammer:
A vulnerability that affects RAM by repeatedly accessing (hammering) a row of memory, triggering electrical interferences that eventually corrupt the data stored inside the RAM.

Meltdown and Spectre:
Google security researchers discovered Meltdown and Spectre, two hardware vulnerabilities that affect almost all central processing units (CPUs) released since 1995 within desktops, laptops, servers, smartphones, smart devices and cloud services.

Attackers exploiting these vulnerabilities can read all memory from a given system (Meltdown), as well as data handled by other applications (Spectre). The Meltdown and Spectre vulnerability exploitations are referred to as side-channel attacks (information is gained from the implementation of a computer system). They have the ability to compromise large amounts of memory data because the attacks can be run multiple times on a system with very little possibility of a crash or other error.

Software Vulnerabilities

Software vulnerabilities are usually introduced by errors in the operating system or application code.

The SYNful Knock vulnerability allowed attackers to gain control of enterprise-grade routers, such as the legacy Cisco ISR routers, from which they could monitor all network communication and infect other network devices.

This vulnerability was introduced into the system when an altered IOS version was installed on the routers. To avoid this, you should always verify the integrity of the downloaded IOS image and limit the physical access of such equipment to authorized personnel only.

Categorizing Software Vulnerabilities

Buffer Overflow: Buffers are memory areas allocated to an application.

- A vulnerability occurs when data is written beyond the limits of a buffer.
- By changing data beyond the boundaries of a buffer, the application can access memory allocated to other processes.

This can lead to a system crash or data compromise, or provide escalation of privileges.

Non-validated input: Programs often require data input, but this incoming data could have malicious content, designed to force the program to behave in an unintended way.

Example: Consider a program that receives an image for processing. A malicious user could craft an image file with invalid image dimensions. The maliciously crafted dimensions could force the program to allocate buffers of incorrect and unexpected sizes.

Race Conditions: This vulnerability describes a situation where the output of an event depends on ordered or timed outputs. A race condition becomes a source of vulnerability when the required ordered or timed events do not occur in the correct order or at the proper time.

Weaknesses in Security Practices: Systems and sensitive data can be protected through techniques such as authentication, authorization and encryption.

Developers should stick to using security techniques and libraries that have already been created, tested and verified and should not attempt to create their own security algorithms.

- These will only likely introduce new vulnerabilities.

Access Control Problems: Nearly all access controls and security practices can be overcome if an attacker has physical access to target equipment. For example, no matter the permission settings on a file, a hacker can bypass the operating system and read the data directly off the disk. Therefore, to protect the machine and the data it contains, physical access must be restricted, and encryption techniques must be used to protect data from being stolen or corrupted.

Software Updates

The goal of software updates is to stay current and avoid exploitation of vulnerabilities. Microsoft, Apple and other operating system producers release patches and updates almost every day and applications such as web browsers, mobile apps and web servers are often updated by the companies or organizations responsible for them.

Despite the fact that organizations put a lot of effort into finding and patching software vulnerabilities, new vulnerabilities are discovered regularly. That's why some organizations use third party security researchers who specialize in finding vulnerabilities in software, or actually invest in their own penetration testing teams dedicated to search, find and patch software vulnerabilities before they can get exploited.

Google's Project Zero is a great example of this practice. After discovering a number of vulnerabilities in various software used by end users, Google formed a permanent team dedicated to finding software vulnerabilities. You can find out more about Google's security research here.

Google's Project Zero is a team of security analysts employed by Google tasked with finding zero-day vulnerabilities in widely used software, including both Google's own products and third-party software used by its users. Announced on 15 July 2014, the team was established in response to growing concerns about the exploitation of unpatched software flaws by criminals, state-sponsored hackers, and intelligence agencies. The initiative was partly influenced by the 2013 global surveillance disclosures by Edward Snowden, which prompted Google to strengthen its security posture.

Project Zero's primary mission is to identify and responsibly disclose critical vulnerabilities, with a strict 90-day disclosure deadline for vendors to release patches before public disclosure. If a patch is not issued within this timeframe, the vulnerability is made public to ensure users can take protective measures. In some cases, an additional 30-day extension is allowed, though this has been criticized by some software maintainers as a form of pressure.

https://project-zero.issues.chromium.org/issues

– – Continued – –

The Cybersecurity Landscape

Cryptocurrency

1. Cryptocurrency owners keep their money in encrypted, virtual ‘wallets.’ When a transaction takes place between the owners of two digital wallets, the details are recorded in a decentralized, electronic ledger or blockchain system.
    a. This means it is carried out with a degree of anonymity and is self-managed, with no interference from third parties such as central banks or government entities.
2. Approximately every ten minutes, special computers collect data about the latest cryptocurrency transactions, turning them into mathematical puzzles to maintain confidentiality.
    a. These transactions are then verified through a technical and highly complex process known as ‘mining.’
    b. This step typically involves an army of ‘miners’ working on high-end PCs to solve mathematical puzzles and authenticate transactions.
3. Once verified, the ledger is updated and electronically copied and disseminated worldwide to anyone belonging to the blockchain network, effectively completing a transaction.

Cryptojacking

Cryptojacking is an emerging threat that hides on a user’s computer, mobile phone, tablet, laptop or server, using that machine’s resources to 'mine’ cryptocurrencies without the user's consent or knowledge.

Many victims of cryptojacking didn’t even know they’d been hacked until it was too late!

Module 3: Protecting your Data and Privacy

The FCC's page on Wireless Connections and Bluetooth Security:
https://www.fcc.gov/consumers/guides/how-protect-yourself-online

Protecting your Devices and Network

Protecting your Computing Devices

1. Turn the Firewall on
2. Install Antivirus and antispyware
3. Manage your operating system and browser
4. Set up password protection

Wireless Network Security at Home

This course is out of date. My notes here:

The best Wi-Fi protection is WPA3. Don't use WPA2 if you can avoid it.

Public Wi-Fi Risks

It is best not to access or send any personal information when using public Wi-Fi.

You should always verify that your device isn't configured with file and media sharing and that it requires user authentication with encryption.

You should also use an encrypted VPN service to prevent others from intercepting your information (known as 'eavesdropping') over a public wireless network.

A Strong Password

1. Do not use dictionary words or names in any languages.
2. Do not use common misspellings of dictionary words.
3. If possible, use special characters such as ! @ # $..
4. Do not use computer names or account names.
5. Use a password with more than ten characters.

Using a Passphrase

1. Choose a statement that is meaningful to you.
2. Add special characters.
3. The longer the better.
4. Avoid common or famous statements, lyrics, poems...

Password Guidelines

The United States National Institute of Standards and Technology (NIST) has published improved password requirements. NIST standards are intended for government applications but can serve as a standard for other sectors as well.

Modern NIST Password Guidelines:

- Passwords should be at least 8 characters, with support for longer passphrases (64+ characters where feasible).
- Common, breached, or context-specific passwords (e.g., “password”, “abc123”, usernames, service names) must be blocked using deny lists.
- Mandatory composition rules (forced uppercase, symbols, numbers) should not be required unless justified by a specific risk assessment.
- Users should be allowed to view the password while entering it to reduce entry errors.
- All printable Unicode characters and spaces should be accepted.
- Password hints must not be used.
- Periodic password expiration must not be enforced unless there is evidence of compromise.
- Knowledge-based authentication (security questions, transaction history) must not be used.
- Authentication systems should support additional protections, such as rate limiting, MFA, and anomaly detection.

Data Maintenance

What is Encryption?

Encryption is the process of converting information into a form in which unauthorized parties cannot read it. Only a trusted, authorized person with the secret key or password can decrypt the data and access it in its original form.

Note that the encryption itself does not prevent someone from intercepting the data. It can only prevent an unauthorized person from viewing or accessing the content. In fact, some criminals may decide to simply encrypt your data and make it unusable until you pay a ransom.

How do you Encrypt your Data?

Software programs are used to encrypt files, folders and even entire drives.

Encrypting File System (EFS) is a Windows feature that can encrypt data. It is directly linked to a specific user account and only the user that encrypts the data will be able to access it after it has been encrypted using EFS.

1. Select one or more files or folders.
2. Right click the selected data and go to ‘Properties.’
3. Find and click ‘Advanced.’
4. Select the ‘Encrypt contents to secure data’ check box.
5. Files and folders that have been encrypted with EFS are displayed in green as shown here.

Back up your Data

Having a backup may prevent the loss of irreplaceable data. To back up data properly, you will need an additional storage location for the data and you must copy the data to that location regularly.

This course got it wrong again: **The cloud should be your *last* option, and very low on any priority list..**
Ideal locations: Local in-house server, external SSDs (over HDDs), NAS Storage, a 2nd physical location..

How do you Delete your Data Permanently?

Tools for data deletion:

- SDelete for Microsoft
- Shred for Linux
- Secure Empty Trash for MacOS

Or Physically destroy the drive via fire or shredder, although even a shredder is potentially less safe than fire. Ironically.

Who Owns your Data?

Terms of Service

A legally binding contract that governs the rules of the relationship between you, the service provider and others who use the service

The Terms of Service will include a number of sections, from user rights and responsibilities to disclaimers and account modification terms.

Understand the Terms

The data use policy outlines how the service provider will collect, use and share your data.

The privacy settings allow you to control who sees information about you and who can access your profile or account data.

The security policy outlines what the company is doing to secure the data it obtains from you.

Before you Sign up

- Have you read the Terms of Service?
- What are your rights regarding your data?
- Can you request a copy of your data?
- What can the provider do with the data you upload?
- What happens to your data when you close your account?

Protect your Data

To protect your data and safeguard your account, you should:

- always read the Terms of Service when registering for a new service and decide whether the service is worth waiving your rights to your data for
- select your privacy settings rather than accepting the default
- limit the group of people you share content with
- review the service provider's security policy to understand what they are doing to protect your data
- change your passwords periodically, use a complex password and two factor authentication to secure your account.

Safeguarding your Online Privacy

Two Factor Authentication

Popular online services, such as Google, Facebook, Twitter, LinkedIn, Apple and Microsoft, use two factor authentication to add an extra layer of security for account logins.

Besides your username and password or personal identification number (PIN), two factor authentication requires a second token to verify your identity. This may be a:

- physical object such as a credit card, mobile phone or fob
- biometric scan such as a fingerprint or facial and voice recognition
- verification code sent via SMS or email.

Open Authorization- REFRAMED NOTES

Open authorization (OAuth) is an open standard protocol that allows you to use your credentials to access third-party applications without exposing your password. This is an old phrase.

This is commonly referred to as **OpenID Connect and Passwordless Authentication**.

Email and Web Browser Privacy

These problems can be minimized by enabling the in-private browsing mode on your web browser. Many of the most commonly used web browsers have their own name for private browser mode:

- Microsoft Internet Explorer: InPrivate
- Google Chrome: Incognito
- Mozilla Firefox: Private tab or private window
- Safari: Private browsing

Module 4: Protecting the Organization

Cybersecurity Devices and Technologies

Security Appliances

Security appliances can be standalone devices like a router or software tools that are run on a network device. They fall into six general categories.

1. Routers
2. Firewalls
3. Intrusion Prevention Systems
4. VPNs
5. Antimalware/Antivirus
6. Other....

– – Continued – –

Firewalls

- **Network Layer Firewall**: This filters communications based on source and destination IP addresses.
- **Transport Layer Firewall**: Filters communications based on source and destination data ports, as well as connection states.
- **Application Layer Firewall**: Filters communications based on an application, program or service.
- **Context Aware Layer Firewall**: Filters communications based on the user, device, role, application type and threat profile.
- **Proxy Server**: Filters web content requests like URLs, domain names and media types.
- **Reverse Proxy Server**: Placed in front of web servers, reverse proxy servers protect, hide, offload and distribute access to web servers.
- **Network Address Translation (NAT) Firewall**: This firewall hides or masquerades the private addresses of network hosts.
- **Host-based Firewall**: Filters ports and system service calls on a single computer operating system.

Port Scanning

In networking, each application running on a device is assigned an identifier called a port number. This port number is used on both ends of the transmission so that the right data is passed to the correct application.
Port scanning is a process of probing a computer, server or other network host for open ports.

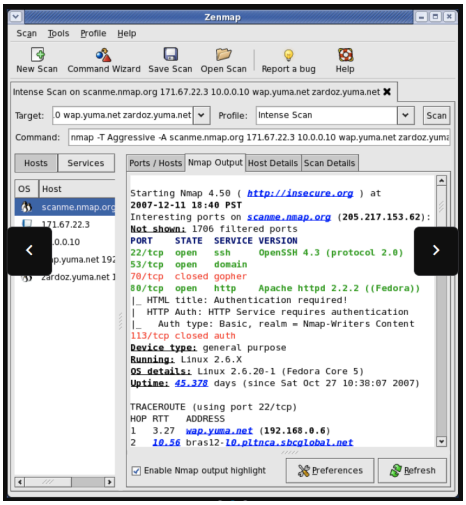
- It can be used maliciously as a reconnaissance tool to identify the operating system and services running on a computer or host, or
- it can be used harmlessly by a network administrator to verify network security policies on the network.

The following notes are regarding the use of nmap and Zenmap.

More information is here: https://nmap.org/zenmap/

Download and launch a port scanning tool like Zenmap.

- Enter the IP address of your computer, choose a default scanning profile and press 'scan.'
    - The scan will report any services that are running, such as web or email services, and their port numbers.



The scan will also report one of the following responses:

1. '**Open**' or '**Accepted**' means that the port or service running on the computer can be accessed by other network devices.
2. '**Closed**,' '**Denied**' or '**Not Listening**' means that the port or service is not running on the computer and therefore cannot be exploited.
3. '**Filtered**,' '**Dropped**' or '**Blocked**' means that access to the port or service is blocked by a firewall and therefore it cannot be exploited.

To execute a port scan from outside of your network, you will need to run it against your firewall or router's public IP address.

Enter the query 'what is my IP address?' into a search engine such as Google to find out this information.

Go to the Nmap Online Port Scanner, enter your public IP address in the input box and press 'Quick Nmap Scan.' If the response is open for ports 21, 22, 25, 80, 443 or 3389 then most likely, port forwarding has been enabled on your router or firewall and you are running servers on your private network.

Intrusion Detection and Prevention Systems

IDS (Intrusion Detection System)

- An IDS monitors traffic and activity to identify suspicious or malicious behavior.
- It detects, logs, and alerts — it does not block traffic.

Compares traffic against:

- Signatures (known attacks)
- Rules/policies
- Sometimes anomaly or behavior baselines

When a match occurs → log + alert (human or SIEM responds).

Deployment types

- NIDS (Network IDS):
    - Off-path (SPAN/TAP port)
    - Sees copies of traffic → no latency impact
- HIDS (Host IDS):
    - Runs on endpoints/servers
    - Watches logs, file changes, processes

Key takeaway
IDS = visibility and evidence, not enforcement.

IPS (Intrusion Prevention System)

What it is

- An IPS actively blocks or drops traffic that matches malicious patterns.
- It detects and prevents attacks in real time.

Uses the same detection methods as IDS:

- Signatures
- Rules
- Behavioral analysis

But runs inline with traffic:

- Can drop packets
- Reset connections
- Deny sessions

Deployment

- Inline with network traffic (firewall, gateway, appliance)
- Because it's inline:
    - Misconfiguration = possible outages
    - Requires careful tuning

Key takeaway
IPS = enforcement and prevention.

– – Continued – –

Real-Time Detection

Detecting attacks in real time requires actively scanning for attacks using firewall and IDS/IPS network devices. Next generation client and server malware detection with connections to online global threat centers must also be used. Today, active scanning devices and software must detect network anomalies using context-based analysis and behavior detection.

DDoS is one of the biggest attack threats requiring real-time detection and response. For many organizations, regularly occurring DDoS attacks cripple Internet servers and network availability. These attacks are extremely difficult to defend against because the attacks originate from hundreds, even thousands, of zombie hosts, and the attacks appear as legitimate traffic.

Protecting Against Malware

One way of defending against zero-day attacks and advanced persistent threats (APTs) is to use an enterprise-level advanced malware detection solution, like **Cisco's Advanced Malware Protection (AMP) Threat Grid**.

This is client/server software that can be deployed on host endpoints, as a standalone server or on other network security devices. It analyzes millions of files and correlates them against hundreds of millions of other analyzed malware artifacts for behaviors that reveal an APT. This approach provides a global view of malware attacks, campaigns and their distribution.

- The Threat Grid allows the Cisco Secure Operations Center team to gather more accurate, actionable data.
- The Incidence Response team therefore has access to forensically sound information from which it can more quickly analyze and understand suspicious behaviors.
- Using this analysis, the Threat Intelligence team can proactively improve the organization's security infrastructure.
- Overall, the Security Infrastructure Engineering team is able to consume and act on threat information faster, often in an automated way.

Security Best Practices

Many national and professional organizations have published lists of security best practices. Some of the most helpful guidelines are found in organizational repositories such as the National Institute of Standards and Technology (NIST) Computer Security Resource Center.

- Perform a Risk Assessment
- Create a Security Policy
    - Must clearly outlines the organization's rules, job roles, and responsibilities and expectations for employees
- Physical Security Measures
- Human Resources Security Measures
- Perform and Test Backups
- Maintain Security Patches and Updates
- Employ Access Controls
- Regularly Test Incident Response
- Implement a network monitoring analytics and management tool
- Implement Network Security Devices
- Implement a Comprehensive Endpoint Security Solution
- Educate users
- Encrypt Data

Behavior Approach to Cybersecurity

Behavior-Based Security

Behavior-based security is a form of threat detection that involves capturing and analyzing the flow of communication between a user on the local network and a local or remote destination. Any changes in normal patterns of behavior are regarded as anomalies, and may indicate an attack.

Honeypots

- A behavior-based detection tool that lures the attacker in by appealing to their predicted pattern of malicious behavior.
- Once inside the honeypot, the network admin can capture, log and analyze their behavior so that they can build a better defense.

Cisco's Cyber Threat Defense Solution Architecture

- Uses behavior-based detection and indicators to provide greater visibility, context and control.
- Employs many security technologies to achieve this goal.
- The aim is to know
    - who is carrying out the attack
    - What type of attack they are performing
    - Where, when and how the attack is taking place.

NetFlow

NetFlow technology is used to gather information about data flowing through a network, including who and what devices are in the network, and when and how users and devices access the network.

NetFlow is an important component in behavior-based detection and analysis. Switches, routers and firewalls equipped with NetFlow can report information about data entering, leaving and traveling through the network.

This information is sent to NetFlow collectors that collect, store and analyze NetFlow data, which can be used to establish baseline behaviors on more than 90 attributes, such as source and destination IP address.

Penetration Testing

Penetration testing, commonly known as pen testing, is the act of assessing a computer system, network or organization for security vulnerabilities. A pen test seeks to breach systems, people, processes and code to uncover vulnerabilities which could be exploited. This information is then used to improve the system's defenses to ensure that it is better able to withstand cyber attacks in the future.

Step 1: Planning

The pen tester gathers as much information as possible about a target system or network, its potential vulnerabilities and exploits to use against it. This involves conducting passive or active reconnaissance (footprinting) and vulnerability research.

Step 2: Scanning

The pen tester carries out active reconnaissance to probe a target system or network and identify potential weaknesses which, if exploited, could give an attacker access. Active reconnaissance may include:

- port scanning to identify potential access points into a target system
- vulnerability scanning to identify potential exploitable vulnerabilities of a particular target
- establishing an active connection to a target (enumeration) to identify the user account, system account and admin account.

Step 3: Gaining Access

The pen tester will attempt to gain access to a target system and sniff network traffic, using various methods to exploit the system including:

- launching an exploit with a payload onto the system
- breaching physical barriers to assets
- social engineering
- exploiting website vulnerabilities
- exploiting software and hardware vulnerabilities or misconfigurations
- breaching access controls security
- cracking weak encrypted Wi-Fi.

Step 4: Maintaining Access

The pen tester will maintain access to the target to find out what data and systems are vulnerable to exploitation. It is important that they remain undetected, typically using backdoors, Trojan horses, rootkits and other covert channels to hide their presence.

When this infrastructure is in place, the pen tester will then proceed to gather the data that they consider valuable.

Step 5: Analysis and Reporting

The pen tester will provide feedback via a report that recommends updates to products, policies and training to improve an organization's security.

Impact Reduction

Actions organizations should take when a security breach is identified:

- Communicate the Issue
- Be Sincere and Accountable
- Provide the Details
- Find the Cause
    - This may involve hiring forensics experts to research and find out the details.
- Apply Lessons Learned
- Check, and check again
    - Attackers will often attempt to leave a backdoor to facilitate future breaches.
- Educate
    - Never stop the effort to raise awareness, train and educate employees, partners and clients on how to prevent future breaches.

What is Risk Management

Risk management is the formal process of continuously identifying and assessing risk in an effort to reduce the impact of threats and vulnerabilities.

You cannot eliminate risk completely but you can determine acceptable levels by weighing up the impact of a threat with the cost of implementing controls to mitigate it.

The cost of a control should never be more than the value of the asset you are protecting.

- Frame the Risk: Identify threats that increase risk.
- Assess the Risk: Determine the severity that each threat poses.
- Respond to the Risk: Develop an action plan to reduce overall organization risk exposure.
- Monitor the Risk: Continuously review any risk reduced through elimination, mitigation or transfer actions.

Cisco's Approach to Cybersecurity

Cisco's CSIRT

Many large organizations operate a **Computer Security Incident Response Team (CSIRT)** to receive, analyze, coordinate, and respond to cybersecurity incidents. Cisco maintains a global CSIRT as part of its Security and Trust Organization. In addition to incident response, Cisco CSIRT performs proactive activities such as threat analysis, vulnerability assessment, incident trend analysis, and security architecture review to reduce the likelihood and impact of future incidents.

Cisco's CSIRT takes a collaborative and intelligence-driven approach, participating in trusted information-sharing communities to stay current on emerging threats and response practices. Cisco is a long-standing member of the **Forum of Incident Response and Security Teams (FIRST)**, which facilitates coordination and best-practice sharing among vetted incident response teams worldwide.

In addition to private-sector CSIRTs, there are national and public incident response organizations that support governments and enterprises. These include national **CSIRTs** and **CERTs**, such as the **CERT Division of the Software Engineering Institute at Carnegie Mellon University**, which provides guidance, research, and coordination support to help organizations develop, operate, and mature their incident response capabilities.

Security Playbook

One of the best ways to prepare for a security breach is to prevent it. Organizations should provide guidance on:

- how to identify the cybersecurity risk to systems, assets, data and capabilities
- the implementation of safeguards and personnel training
- a flexible response plan that minimizes the impact and damage in the event of a security breach
- security measures and processes that need to be put in place in the aftermath of a security breach.

All this information should be compiled into a security playbook.

A security playbook is a collection of repeatable queries or reports that outline a standardized process for incident detection and response. Ideally, a security playbook should:

- highlight how to identify and automate the response to common threats such as the detection of malware-infected machines, suspicious network activity or irregular authentication attempts.
- describe and clearly define inbound and outbound traffic.
- provide summary information including trends, statistics and counts.
- provide usable and quick access to key statistics and metrics.
- correlate events across all relevant data sources.

Tools for Incident Detection and Prevention

Security Information and event Management (SIEM)

- Collects and analyzes security alerts, logs and other real-time and historical data from security devices on the network to facilitate early detection of cyber attacks.

Data Loss Prevention (DLP)

- A system designed to stop sensitive data from being stolen from or escaping a network.
- It monitors and protects data in three different states:
    - Data in use
    - Data in motion
    - Data at rest

Cisoco's ISE and TrustSec

Cisco Identity Services Engine (ISE) and TrustSec enforce user access to network resources by creating role-based access control policies.

Talk the Talk

Module 5: Will Your Future Be In Cybersecurity?

Legal and Ethical Issues

Legal Issues in Cybersecurity

In order to protect against attacks, cybersecurity professionals must have the same skills as the attackers. However, cybersecurity professionals use their skills within the bounds of the law.

Personal Legal Issues:

- At work or home, you may have the opportunity and skills to hack another person's computer or network. But there is an old saying, 'Just because you can does not mean you should.' Most hacks leave tracks, which can be traced back to you.
- Cybersecurity professionals develop many skills, which can be used positively or illegally. There is always a huge demand for those who choose to put their cyber skills to good use within legal bounds.

Corporate Legal Issues:

- Most countries have cybersecurity laws in place, which businesses and organizations must abide by.
- In some cases, if you break cybersecurity laws while doing your job, the organization may be punished and you could lose your job. In other cases, you could be prosecuted, fined and possibly sentenced.
- In general, if you are unsure whether an action or behavior might be illegal, assume that it is illegal and do not do it. Always check with the legal or HR department in the organization.

International Law and Cybersecurity

- International cybersecurity law is a constantly evolving field. Cyber attacks take place in cyberspace, an electronic space created, maintained and owned by both the public and private entities. There are no traditional geographic boundaries in cyberspace. To further complicate issues, it is much easier to mask the source of an attack in cyberwarfare than in conventional warfare.
- The global society is still debating how best to deal with cyberspace. Country practice, opinio juris (a sense on behalf of a country that it is bound to the law in question) and any treaties drafted will shape international cybersecurity law.

Ethical Issues in Cybersecurity

Think back to the pen test you carried out for @Apollo. This test revealed that one of your colleagues, who started at the same time as you, was responsible for a data breach. You are thinking of not including this in your report as they might get in trouble.
Ask yourself the following questions to help you decide on the best course of action.

- Is it legal?
- Does your action comply with @Apollo policy?
- Will your action be favorable for @Apollo and its stakeholders?
- Would it be okay if everyone in @Apollo took this action?
- Would the outcome of your action represent @Apollo in a positive light in a news headline?

Corporate Ethical Issues

Many professional IT organizations such as the Information Systems Security Association (ISSA) have published Codes of Ethics to help guide employee actions and behaviors.

Cisco also has a team devoted exclusively to ethical business conduct and a Code of Business Conduct to help employees make business decisions and resolve any issues they may encounter.

Education and Careers

Professional Certifications

Cisco Certified Support Technician (CCST) Cybersecurity
This is an entry-level certification for newcomers who are preparing to start their career in the cybersecurity field. It is aimed at high school and early college students as well as those interested in a career change. This certificate does not expire or require periodic recertification.

CompTIA Security+
This is an entry-level security certification that meets the U.S. Department of Defense Directive 8570.01-M requirements, which is an important item for anyone looking to work in IT security for the federal government.

EC Council Certified Ethical Hacker (CEH)
This certification tests your understanding and knowledge of how to look for weaknesses and vulnerabilities in target systems using the same knowledge and tools as a malicious hacker but in a lawful and legitimate manner.

ISC2 Certified Information Systems Security Professional (CISSP)
This is the most recognizable and popular security certification. In order to take the exam, **you need to have at least five years of relevant industry experience**.

Cisco Certified CyberOps Associate
This certification validates the skills required of associate-level cybersecurity analysts within security operations centers.

Cybersecurity Career Pathways

CyberSeek is a tool that provides detailed data about supply and demand in the cybersecurity job market to help close the cybersecurity skills gap. Click here to view the interactive career pathway which shows the range of jobs in cybersecurity, as well as detailed information about the salaries, credentials and skill sets associated with each job.